

Social Engineering & Email Security

1. Social Engineering: Social engineering is the manipulation of people into performing actions or divulging confidential information. It exploits human psychology rather than technical hacking techniques. Attackers rely on trust, urgency, fear, or curiosity to trick users into breaking security practices.

2. Common Types of Social Engineering Attacks:

- **Phishing:** Sending fraudulent emails that appear to be from reputable sources to steal credentials or sensitive data.
 - **Pretexting:** Creating a fabricated scenario to convince someone to give up information.
 - **Baiting:** Leaving infected devices (like USBs) in places to tempt users into plugging them in.
 - **Tailgating:** Gaining physical access by following someone into a secure building.
 - **Quid Pro Quo:** Offering a service in exchange for information (e.g., fake IT support).
-

3. Case Study: The 2020 Twitter Bitcoin Scam

- **Overview:**
In July 2020, attackers compromised Twitter's internal tools and hijacked high-profile accounts, including those of Elon Musk, Barack Obama, and Apple.
 - **How it happened:**
The attackers used **social engineering techniques** to trick Twitter employees into giving access to internal admin tools. Once inside, they reset email addresses and passwords of verified users.
 - **Result:**
The attackers posted Bitcoin scam tweets from verified accounts, collecting over **\$100,000** in cryptocurrency within hours.
 - **Takeaway:**
Even well-funded tech companies are vulnerable to human-based attacks. Insider access and lack of employee awareness played a major role in this breach.
-

4. Awareness Article: Why Cybersecurity Awareness Matters

Title: "Humans Are the First Line of Defense"

With rising digital threats, having advanced firewalls and encryption is not enough. Most cyberattacks begin with human error — clicking a malicious link, sharing passwords, or trusting a fake caller. That's where **cybersecurity awareness** comes in.

Organizations must train employees to recognize suspicious behavior, verify identities before disclosing data, and follow safe digital practices. Regular awareness programs, phishing simulations, and strong communication are vital.

Remember, it takes just one unaware person to open the door for a cybercriminal. Security is everyone's responsibility.

Phishing Attacks & Email Security

1. How Phishing Attacks Work

Phishing attacks usually involve deceptive emails or messages designed to appear legitimate. Attackers spoof email addresses and create urgent messages to trick users into clicking malicious links, downloading malware, or entering sensitive information like passwords.

2. How to Identify a Phishing Email

- Check sender's email domain (e.g., support@paypa1.com instead of paypal.com)
 - Look for poor grammar or urgent language ("Your account will be locked!")
 - Hover over links before clicking – do they match the claimed destination?
 - Unexpected attachments or requests for credentials
 - Generic greetings like "Dear User"
-

3. Real Phishing Email Example (Analyzed Safely)

- **Subject:** Urgent! Your Office365 Password Expires Today
 - **Details:**
 1. Sender: it-support@microsoft-mail.com
 2. Message: "Click here to reset your password or you'll lose access."
 3. Link: Redirected to <http://fake-office365-login.gq>
 - **Indicators of Phishing:**
 1. Fake domain (microsoft-mail.com)
 2. Urgent language
 3. Link leads to an unofficial site
-

4. Email Security Best Practices

To reduce phishing risks, email authentication mechanisms can be implemented:

- **SPF (Sender Policy Framework):** Defines which servers are allowed to send mail on behalf of a domain.
- **DKIM (DomainKeys Identified Mail):** Adds a digital signature to email headers to verify the sender's identity.

- **DMARC (Domain-based Message Authentication, Reporting & Conformance):** Builds on SPF and DKIM to give domain owners control over how unauthenticated emails are handled.